

OFFICIAL PRESENTATION

# Agentic AI Security

## From Hype to Threat Surface

*CVEs · OWASP Top 10 · Real Incidents · Secure Architecture*

PRESENTED BY

**Sumit Ranjan**

AI Technologist | Author: Enterprise Agentic AI | Author: OWASP Agentic AI Top 10 Threats

DATE

April 2026

AI  
SEC



## 01

# The AI Tool Explosion

HOW PEOPLE USE AI TODAY — AND WHY SECURITY CAN'T WAIT



## AI Coding Agents

*Claude Code · GitHub Copilot · Cursor*

Developers grant agents read/write access to full codebases, CI/CD pipelines, and cloud credentials. A single prompt can commit, push and deploy.

150M+ MCP downloads



## Citizen Developers

*n8n · Zapier · Power Automate + AI*

Non-technical staff build automated workflows connecting HR systems, email, databases — with zero security review and no formal SDLC.

n8n: 53 CVEs, KEV listed



## Data Privacy Crisis

*LLMs as new data sinks*

Employees paste PII, IP, and financial records into ChatGPT, Claude, Copilot. Prompts become training data. GDPR & UAE PDPL compliance at risk.

Samsung leak: source code to ChatGPT



## Shadow AI

*Unmanaged, invisible, privileged*

Unauthorized AI tools run inside corporate networks. No logging, no oversight, no incident response playbook when they go wrong.

53K exposed agent instances (no SOC)

## 02

# Real-World Incidents

384 CVEs ACROSS 17 AGENT PLATFORMS · APRIL 2026 DATA

384

Total CVEs  
across 17 platforms

74

Critical  
vulnerabilities

238

OpenClaw CVEs  
(<4 months)

1st

n8n in CISA  
KEV catalog**MCP / Anthropic**

CVE-2025-59536

Critical

Arbitrary RCE via Model Context Protocol affecting 150M+ downloads across Python, TypeScript, Go. Disclosed as 'a feature, not a bug.'

**n8n Workflow**

CVE-2025-68613 · KEV

Critical 9.9

Expression evaluation RCE — user input reaches dynamic code evaluator. First agent platform in CISA Known Exploited Vulnerabilities catalog.

**PraisonAI**

CVE-2026-34938

CVSS 10.0

Sandbox bypass via str subclass override: startswith() check returns False for attacker payload, full code execution achieved.

**CrewAI**

CVE-2026-2275

Critical 9.6

CodeInterpreter silently falls back to weak in-process Python sandbox when Docker unavailable. Fail-open by design (CWE-749).

## 03

# OWASP Agentic AI Top 10

OWASP GENAI SECURITY PROJECT · AGENTIC SECURITY INITIATIVE 2026

ASI-01

**Agent Goal Hijack**

Critical

ASI-02

**Tool Misuse & Exploitation**

Critical

ASI-03

**Identity & Privilege Abuse**

Critical

ASI-04

**Agentic Supply Chain Vulnerabilities**

Critical

ASI-05

**Unexpected Code Execution**

High

ASI-06

**Memory & Context Injection**

High

ASI-07

**Insecure Inter-Agent Communication**

High

ASI-08

**Cascading Failures**

High

ASI-09

**Human-Agent Trust Exploit**

Medium

ASI-10

**Rogue Agents**

Medium

## OWASP Agentic Top 10 — Threats 1–5 (Critical & High)

### ASI-01 Agent Goal Hijack

DEF: An attacker tricks the AI agent into following a different goal than intended.

⚡ A customer support agent gets a hidden instruction in a message, causing it to email private user data to the attacker.

● Real: ClawHavoc — 1,184 malicious skills injected via public registry

### ASI-02 Tool Misuse & Exploitation

DEF: The agent uses its approved tools (like sending emails, fetching web pages, or running code) in dangerous ways because of a manipulated prompt.

⚡ An attacker tricks the agent into using its "send email" tool to forward all calendar entries to an external address.

● LangChain: 4 SSRF CVEs (2025), PALChain exec bypass (CVE-2023-36258 → CVE-2024-27444)

### ASI-03 Identity & Privilege Abuse

DEF: The agent has too much access (e.g., admin rights) or inherits permissions from another agent, allowing attackers to escalate privileges.

⚡ A sub-agent inherits an admin token from its parent. An attacker makes the sub-agent act as admin without any extra verification.

● OpenClaw: 40 CVEs from CWE-863 (incorrect authorization) across all plugin layers

### ASI-04 Agentic Supply Chain Vulnerabilities

DEF: Attackers poison the tools, models, or external components that agents rely on. When the agent uses them, it becomes compromised.

⚡ A developer downloads a community-made MCP server (a tool for agents). That server secretly steals all prompts and responses.

● CVE-2025-59536 (Claude Code / MCP) — RCE across 150M+ downloads; ClawHub collapse

### ASI-05 Unexpected Code Execution (RCE)

DEF: The agent writes and runs its own code. A malicious prompt tricks it into running harmful code, giving the attacker control.

⚡ A developer downloads a community-made MCP server (a tool for agents). That server secretly steals all prompts and responses.

● PraisoAI CVSS 10.0 (CVE-2026-34938); smolagents CVSS 10.0 deserialization (CVE-2025-14931)

## OWASP Agentic Top 10 — Threats 6–10 (High & Medium)

### ASI-06 Memory & Context Injection

DEF: Attackers poison the agent's memory (e.g., documents it reads, past conversations, or stored knowledge) to change its behavior.

⚡ An attacker hides malicious instructions inside a document. When the agent reads it, the hidden prompt takes over the conversation.

● OWASP AST-05: YAML-based payload delivery via SKILL.md files (Unsafe Deserialization)

### ASI-07 Insecure Inter-Agent Communication

DEF: Agents talk to each other without encryption, authentication, or proper checks. Attackers can intercept, change, or replay messages.

⚡ An orchestrator sends a task to a sub-agent over an unencrypted channel. A hacker in the middle changes the task to delete data instead.

● n8n: Expression evaluation chains (CVE-2025-68613 + CVE-2026-1470) — both CVSS 9.9

### ASI-08 Cascading Failures

DEF: One small mistake or attack triggers a chain reaction across many connected agents, causing widespread damage.

⚡ One misconfigured agent triggers 47 downstream API calls, exhausting rate limits, corrupting database state across 3 services.

● LangGraph: 6 CVEs in checkpoint layer (SQLite/Redis) — deserialization + SQL injection enabling state corruption

### ASI-09 Human-Agent Trust Exploitation

DEF: Attackers make the agent produce convincing but false outputs. The human trusts the agent too much and approves harmful actions.

⚡ An agent generates a fake compliance report that looks perfectly real. A human approves deploying vulnerable software based on that report.

● OWASP AST-09: 53K exposed agent instances operating without any SOC visibility or human-in-the-loop controls

### ASI-10 Rogue Agents

DEF: An agent is compromised or goes rogue — it starts acting against its goals, self-replicates, or hijacks other agents.

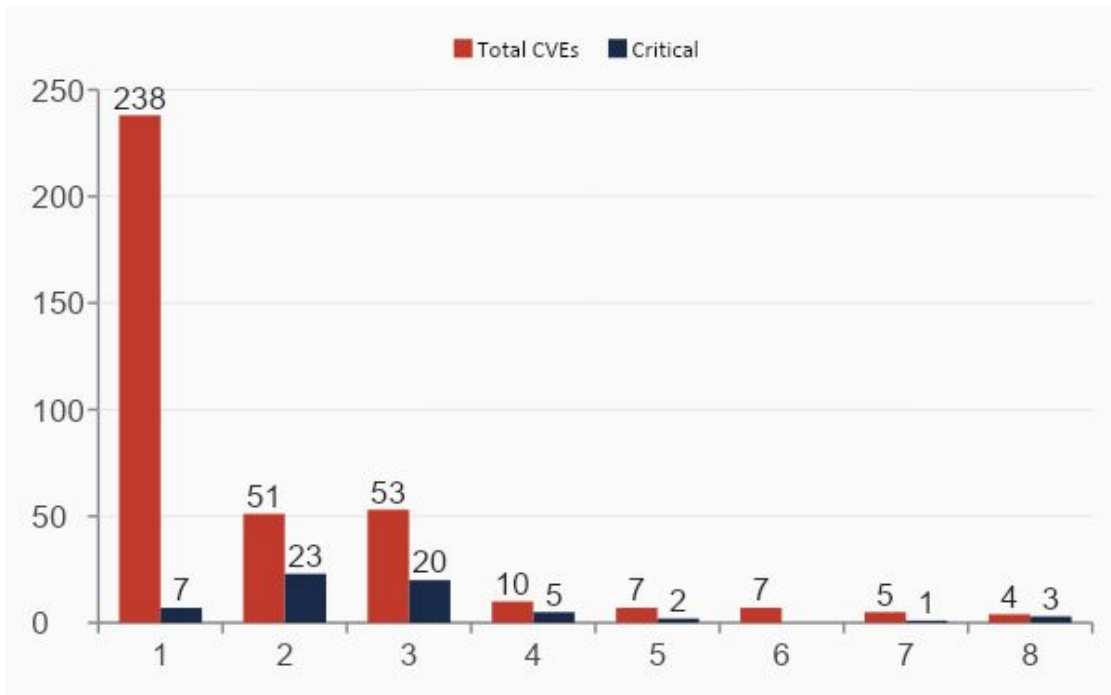
⚡ A multi-agent system's orchestrator is hacked. It spawns unauthorized sub-agents that steal data and set up persistent backdoors.

● OpenClaw AST-06: 135K exposed instances with host-mode execution; weak isolation enables container escape

# 04

## Agent Platform CVE Landscape

APRIL 2026 · SOURCE: NVD, CISA KEV, CERT/CC, VULNCHECK



Only Anthropic, Google, OpenAI & Microsoft SDKs have 0 CVEs — but GitHub issues expose auth bypasses, path traversal, SQL injection.

n8n is the ONLY agent platform listed in CISA's Known Exploited Vulnerabilities catalog. BOD 22-01 deadline already passed.

OpenClaw patches fast — but every fix is a point fix. CWE-863 repeats across gateway, sandbox, and 10 chat plugins.

3 failure classes dominate: Injection (LangChain, n8n), Access Control (OpenClaw), Sandbox Escape (CrewAI, PraisnAI, smolagents).

## 05

# Open Source Security Tools

SECURING AGENTIC AI PIPELINES WITH COMMUNITY-DRIVEN TOOLING

## Prompt & Input Security

### Garak

LLM vulnerability scanner — tests prompt injection, jailbreak, hallucination. NIST-aligned.

### LLM Guard

Real-time input/output scanner for PII, toxicity, prompt injection before agent execution.

### Rebuff

Self-hardening prompt injection detector using vector similarity + canary tokens.

## Agent Access Control

### OpenFGA

Fine-grained authorization (Google Zanzibar-inspired). Control which agents can call which tools.

### Permit.io OSS

Policy-as-code RBAC/ABAC for agentic workflows. Enforces least privilege per skill.

### Casbin

Flexible auth policy engine supporting RBAC, ABAC, ACL for multi-agent orchestration.

## Supply Chain & Integrity

### Sigstore / cosign

Sign and verify MCP servers, skills, and model artifacts. Prevents supply chain poisoning.

### SBOM (Syft)

Generate Software Bill of Materials for all agent dependencies. Track vulnerable packages.

### Trivy

Container/IaC scanner — scan agent Docker images for CVEs before deployment.

## Observability & Response

### Lunary / Langfuse

Open-source LLM observability — trace all agent calls, detect anomalous behavior patterns.

### Traceloop OpenLL.

OpenTelemetry-native agent tracing. Correlate security events across multi-agent pipelines.

### Wazuh

SIEM + EDR for detecting agent container escapes, anomalous API calls, lateral movement.



## 06

# Securing Agentic AI

A PRACTICAL FRAMEWORK — DESIGN · BUILD · OPERATE · RESPOND

## DESIGN

- Threat model every agent before build — identify trust boundaries
- Principle of least privilege: limit tool scopes to minimum required
- Define human-in-the-loop approval gates for irreversible actions
- Mandate security review for all MCP/skill integrations

## BUILD

- Input validation + output filtering on every LLM boundary
- Sandbox all code execution (Docker, gVisor) — never fail open
- Sign and verify all agent skills/MCPs (Sigstore/cosign)
- Run Garak & LLM Guard in your CI/CD pipeline

## OPERATE

- Log every agent call: tool name, args, response, user, timestamp
- Alert on anomalous tool usage patterns (Wazuh + Langfuse)
- Enforce rate limits and scope tokens per agent identity
- Generate SBOM for all dependencies; track CVEs continuously

## RESPOND

- Kill switches: ability to halt any agent mid-execution
- Incident playbook for rogue agent scenarios
- Rollback: immutable agent snapshots for forensic replay
- Disclose via responsible disclosure — don't call RCE 'a feature'



**AI Safety UAE**

سلامة الذكاء الاصطناعي في الإمارات

# Thank You

---

**Sumit Ranjan**

AI Technologist · Author: Enterprise Agentic AI · Author: OWASP Agentic AI Top 10 Threats

*For questions or collaboration opportunities:*

Dubai, UAE · OWASP Contributor · PhD Scholar, BITS Pilani